

CYBERSECURITY LAB

Alessandro Renda

Dipartimento di Ingegneria e Architettura, Università degli Studi di Trieste

Static Code Analysis – LAB

Academic Year 2025/2026

Exam

Folder name for material submission **07_SAST**

Individual Activity

- Analyze at least **two repos** of your interest ...
 - At least one with known security issues
 - At least one without known security issues
- ... by using
 - At least one SAST tool (e.g., SonarCloud)
 - At least one SCA tool (e.g., Dependency Check)
- Please coordinate so that everyone analyzes different repositories (no duplicates)

Individual Activity – w/ known issues

- Some ideas
 - Known vulnerable apps
 - Focus on specific challenges of OWASP Juice Shop
 - Query NVD catalog
 - “open source” <https://nvd.nist.gov/vuln/search#/nvd/home?keyword=open%20source>
 - “wordpress” or “drupal” <https://nvd.nist.gov/vuln/search#/nvd/home?keyword=wordpress>
 - Benchmarking repositories
 - <https://github.com/vulnerable-code/SAST-Benchmark/blob/main/applications.json>
 - News, blog, ecc...
 - <https://github.com/isaacs/node-glob/security/advisories/GHSA-5j98-mcp5-4vw2>
 - <https://github.com/translated/lara-mcp/security/advisories/GHSA-xj5p-8h7g-76m7>
 - ...

Individual Activity – w/o known issues

- Some ideas
 - Your own repositories
 - Public administration
 - [pagopa](#)
 - [AglD](#)
 - [ministero-salute](#)
 - [italia](#)
 - [teamdigitale](#)
 - ...

Presentation of findings

- Prepare a short presentation with the interesting findings, e.g.:
 - Detection of known issues
 - Detection of “previously unknown” issues
 - False positives
 - False negatives
- Keep your slides anonymous

- Today, last part of the lecture
 - Upload them to the “Submission” folder
 - Present your slide to the class: 5/ 10 minutes each

Slide preparation

- Slide structure (no more than 10 slides)
 - 1: Name of the repositories analyzed, links, and tools used
 - 2-3: Short description of the repositories, why they are selected, why they are interesting
 - 4+: few bullet points with the most relevant findings and lessons learned from the analysis of each repository. Include screenshots if you deem relevant.

Exam

- Just upload your slides in the relevant folder of your repository for exam material submission
- You are NOT expected to produce a report for this lab

A recent example: phpMyFAQ (I)

- NVD record: <https://nvd.nist.gov/vuln/detail/CVE-2025-62519>
- Security issue, w/ PoC: <https://github.com/thorsten/phpMyFAQ/security/advisories/GHSA-fxm2-cmwj-qvx4>

```
// ...
public function save(Request $request): JsonResponse
{
    $this->userHasPermission(PermissionType::CONFIGURATION_EDIT);

    $configurationData = $request->get('edit');
    // ...

    foreach ($configurationData as $key => $value) {
        // The key from the user input is used to build the $newConfigValues array.
        $newConfigValues[$key] = (string) $value;
        // ...
    }

    // ...
    // The array, containing user-controlled keys, is passed to
    $this->configuration->update($newConfigValues);

    return $this->json(['success' => Translation::get('ad_conf')]);
}
```

*This method handles the saving of application-wide configuration settings. It retrieves all submitted form data as an associative array [...] keys are **trusted implicitly** and are not sanitized or validated*

A recent example: phpMyFAQ (2)

- NVD record: <https://nvd.nist.gov/vuln/detail/CVE-2025-62519>
- Security issue, w/ PoC: <https://github.com/thorsten/phpMyFAQ/security/advisories/GHSA-fxm2-cmwj-qvx4>

```
public function update(array $newConfigs): bool
{
    // ...
    foreach ($newConfigs as $name => $value) {
        if ($name != 'main.phpMyFAQToken' && !in_array($name, $runtimeConfigs)) {
            // VULNERABLE CODE: The array key '$name' is not escaped and is directly
            // concatenated into the SQL query string. The value is escaped, but not the name.
            $update = sprintf(
                "UPDATE %s%s SET config_value = '%s' WHERE config_name = '%s'",
                Database::getTablePrefix(),
                $this->tableName,
                $this->getDb()->escape(trim($value)),
                $name
            );

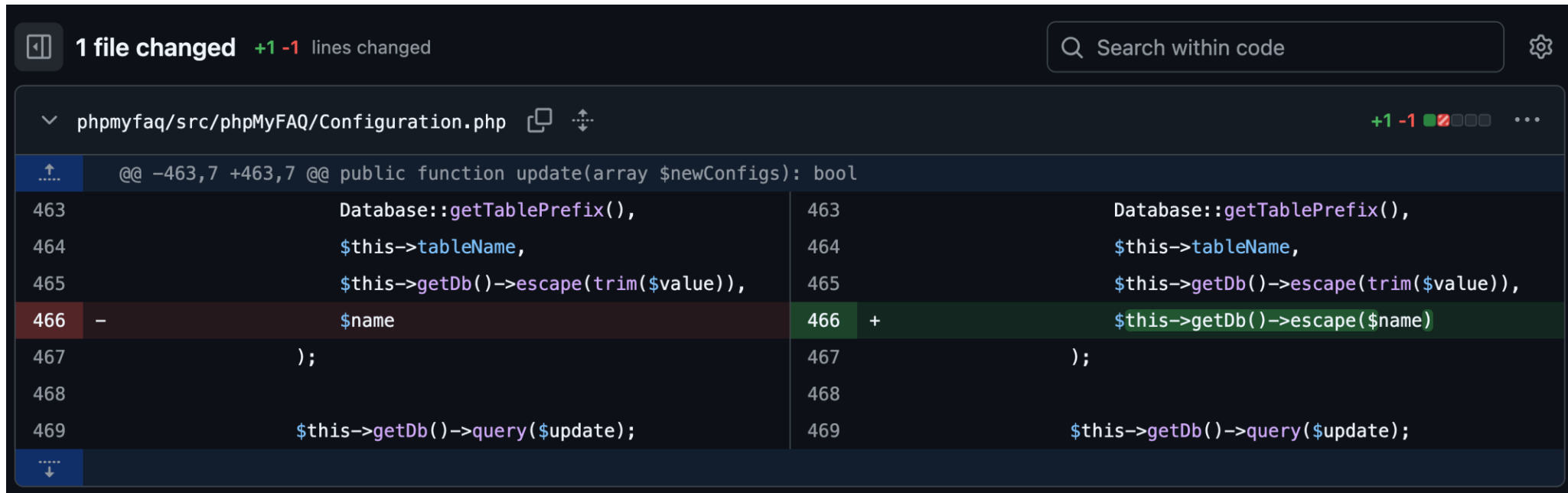
            $this->getDb()->query($update);
            // ...
        }
    }

    return true;
}
```

[...] An attacker can craft a malicious form parameter name (which becomes the array key) to break out of the single quotes in the *WHERE* clause and inject arbitrary SQL commands.

A recent example: phpMyFAQ – History

- History <https://github.com/thorsten/phpMyFAQ/commit/b32e1fbb73f2aa50367a46ffda8e131661084286>
 - ...
 - v4.0.14 patched
 - v4.0.13 vulnerable
 - ...



```
1 file changed +1 -1 lines changed
Search within code

phpmyfaq/src/phpMyFAQ/Configuration.php +1 -1

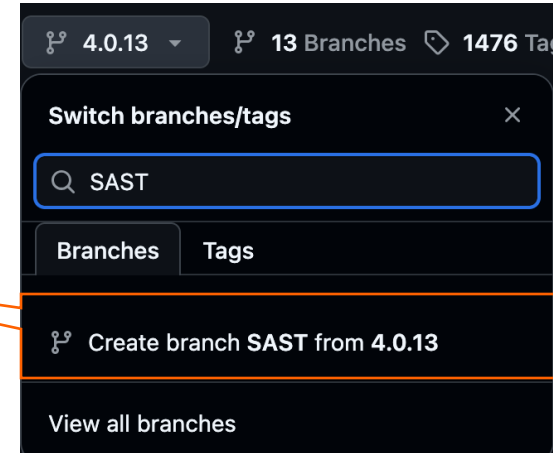
@@ -463,7 +463,7 @@ public function update(array $newConfigs): bool
    Database::getTablePrefix(),
    $this->tableName,
    $this->getDb()->escape(trim($value)),
-   $name
+   $this->getDb()->escape($name)
    );
    $this->getDb()->query($update);
```

How to analyze a specific branch (with SonarCloud free version)

1. Fork the repository (disabling the option “copy the main branch only”).

In the forked repo:

2. Switch to the relevant branch/tag
3. Create branch “SAST” from the current branch/tag
4. Click on “View all branches”
 - a) Rename the existing “main” branch in “main-old”
 - b) Rename the “SAST” branch in “main”
5. In the repo Settings → General → Default branch (switch from “main-old” to “main”)
6. Analyze the repo (“new project”) with SonarCloud: the relevant branch will be analyzed



... bad news

phpMyFAQ > phpmyfaq > src > phpMyFAQ > Configuration.php

phpMyFAQ	Lines	Duplications	Security	Reliability	Maintainability	Security Hotspot
phpmyfaq/src/phpMyFAQ/Configuration.php	558	0.0%	0	0	1	0

```

446 thorst... public function update(array $newConfigs): bool
447 thorst... {
448 thorst...     $runtimeConfigs = [
449 thorst...         'core.database', // phpMyFAQ\Database\DatabaseDriver
450 thorst...         'core.instance', // Instance
451 thorst...         'core.language', // Language
452 thorst...         'core.ldapServer', // Ldap
453 thorst...         'core.ldapConfig', // $LDAP
454 thorst...         'core.elasticsearch', // Elasticsearch\Client
455 thorst...         'core.elasticsearchConfig', // $ES
456 thorst...         'core.pluginManager', // PluginManager
457 thorst...     ];
458
459 thorst...     foreach ($newConfigs as $name => $value) {
460 thorst...         if ($name != 'main.phpMyFAQToken' && !in_array($name, $runtimeConfigs)) {
461 thorst...             $update = sprintf(
462 thorst...                 "UPDATE %s%s SET config_value = '%s' WHERE config_name = '%s'",
463 thorst...                 Database::getTablePrefix(),
464 thorst...                 $this->tableName,
465 thorst...                 $this->getDb()->escape(trim($value)),
466 thorst...                 $name
467 thorst...             );
468 thorst...             $this->getDb()->query($update);
469 thorst...             if (isset($this->config[$name])) {
470 thorst...                 unset($this->config[$name]);
471 thorst...             }
472 thorst...         }
473 thorst...     }
474 thorst... }
475 thorst...
476 thorst... return true;
  
```

- No “security issue” detected
 - *Open question: why??*

Keep in mind: no silver bullet !!